



AWS Identity and Access Management (IAM)

Lecture Slides

These lecture slides are provided for personal and non-commercial use only

Please do not redistribute or upload these lecture slides elsewhere.

Good luck on your exam!

AWS Identity and Access Management (IAM)



AWS Identity and Access Management (IAM) you can create and manage AWS users and groups and use permissions to allow and deny their access to AWS resources.



IAM Policies

JSON documents that grant permissions for a specific user, group, or role to access services. Policies are attached to **IAM Identities**

IAM Permission

The API actions that can or cannot be performed.
They are represented in the IAM Policy document

IAM Identities



IAM Users

End users who log into the console or interact with AWS resources programmatically or via clicking UI interfaces



IAM Groups

Group up your Users so they all share permission levels of the group eg. Administrators, Developers, Auditors



IAM Roles

Roles grant AWS resources permissions to specific AWS API actions
Associate policies to a Role and then assign it to an AWS resource

IAM - Managed vs Customer vs Inline Policy

Managed Policies

A policy that is managed by AWS, which you cannot edit. Managed policies are labeled with an **orange box**

		Policy name ▼	Type
☐	▶	 AmazonEC2FullAccess	AWS managed

Customer Managed Policies

A policy created by the customer which is editable. Customer policies have no symbol beside them.

		Policy name ▼	Type
☐	▶	AmazonSageMaker-Executi...	Customer managed

Inline Policies

A policy that is directly attached to the user.

 **Add inline policy**

Anatomy of an IAM Policy

IAM Policies are written in JSON and contain the permissions which determine what API actions are allowed or denied.

Version policy language version.

2012-10-17 is the latest version.

Statement container for the policy element you are allowed to have multiples

Sid (optional) is a way of labeling your statements.

Effect Set whether the policy will Allow or Deny

Action list of actions that the policy allows or denies

Principal account, user, role, or federated user to which you would like to allow or deny access

Resource the resource to which the action(s) applies

Condition (optional) circumstances under which the policy grants permission

```
{
  "Version": "2012-10-17",
  "Statement": [{
    "Sid": "Deny-Barclay-S3-Access",
    "Effect": "Deny",
    "Action": "s3:*",
    "Principal": {"AWS": ["arn:aws:iam:123456789012:barclay"]},
    "Resource": "arn:aws:s3:::my-bucket"
  }, {
    "Effect": "Allow",
    "Action": "iam:CreateServiceLinkedRole",
    "Resource": "*",
    "Condition": {
      "StringLike": {
        "iam:AWSServiceName": [
          "rds.amazonaws.com",
          "rds.application-autoscaling.amazonaws.com"
        ]
      }
    }
  }
  ]
}
```

Principle of Least Privilege (PoLP)

Principle of Least Privilege (PoLP) is the computer security concept of providing a user, role, or application the least amount of permissions to perform an operation or action.

Just-Enough-Access (JEA)

Permitting only the exact actions for the identity to perform a task

Just-In-Time (JIT)

Permitting the smallest length of duration an identity can use permissions



ConsoleMe is an open-source Netflix project to self-serve short-lived IAM policies so an end user can access AWS resources while enforcing JEA and JIT

<https://github.com/Netflix/consoleme>

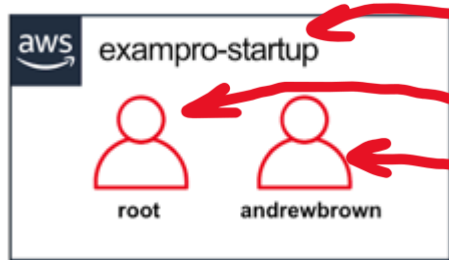
Risk-based adaptive policies

Each attempt to access a resource generates a risk score of how likely the request is to be from a compromised source. The risk score could be based on many factors e.g. device, user location, IP address what service is being accessed and when.



AWS at the time of this recording does not have Risk-based adaptive policies built into IAM

AWS Account Root User



AWS Account – the account which holds all your AWS resources

AWS Account - Root User – a special account with full access that cannot be deleted

AWS Account – User – a user for common tasks that is assigned permissions

AWS Account Root User is a special user who is created at the time of AWS account creation:

- The Root User account uses an Email and Password to login
 - A regular user has to provide the Account ID / Alias, Username and Password
- The Root User account can not be deleted
- The Root User account has full permissions to the account and its permissions ***cannot be limited.**
 - You cannot use IAM policies to explicitly deny the root user access to resources.
 - You can only use an AWS Organizations service control policy (SCP) to limit the permissions of the root user
- There can only be one Root user per AWS account
- The root user is instead for very specific and specialized tasks that are infrequently or rarely performed
 - An AWS Root Account should not be used for daily or common tasks
- Its strongly recommended to never use Root User Access Keys
- Its strongly recommended to turn on MFA for the Root User

IAM – Password Policy

In IAM, you can set a **Password Policy**

To set the minimum requirements of a password and **rotate** passwords, so users have to update their passwords after X days

Minimum password length:

6

☐

Require at least one uppercase letter ?

☐

Require at least one lowercase letter ?

☐

Require at least one number ?

☐

Require at least one non-alphanumeric character ?

☒

Allow users to change their own password ?

☐

Enable password expiration ?

Password expiration period (in days):

☐

Prevent password reuse ?

Number of passwords to remember:

☐

Password expiration requires administrator reset ?

Apply password policy

Delete password policy

IAM - Access Keys

Access Keys allow users to interact with AWS service **programmatically** via the AWS CLI or AWS SDK

You're allowed two Access keys per user.

Access keys

Use access keys to make secure REST or HTTP Query protocol requests. As a best practice, we recommend frequent key rotation. [Learn more](#)

Create access key

Access key ID	Created	Last used	Status	
AKIAZRJIQN2OHMMF5ZFE	2019-09-04 21:51 EDT	N/A	Active	Make inactive ✕

Create access key



Success

This is the **only** time that the secret access keys can be viewed or downloaded. You cannot recover them later. However, you can create new access keys at any time.



Download .csv file

Access key ID

AKIAZRJIQN2OLGRB6Y6V

Secret access key

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 [Hide](#)

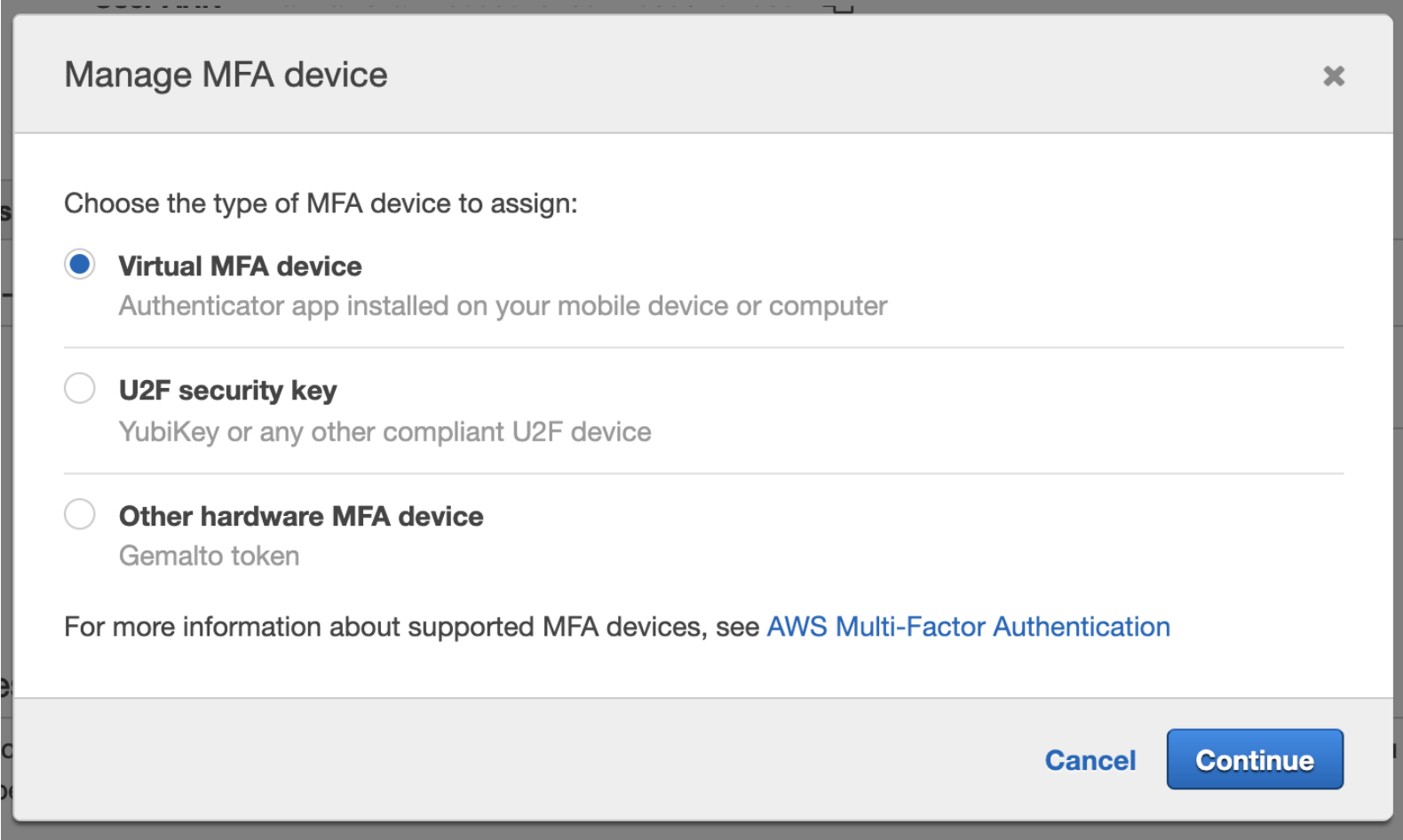
Close

IAM – MFA

Multi-factor authentication (MFA) can be turned on per user.

Users can manage their own MFA devices and settings. Administrators also have the capability to enforce MFA for IAM users.

The Administrator account could create a policy requiring MFA to access certain resources.



The screenshot shows a 'Manage MFA device' dialog box with a close button (X) in the top right corner. The main heading is 'Manage MFA device'. Below it, the text 'Choose the type of MFA device to assign:' is followed by three radio button options:

- ☒ **Virtual MFA device**
Authenticator app installed on your mobile device or computer
- ☐ **U2F security key**
YubiKey or any other compliant U2F device
- ☐ **Other hardware MFA device**
Gemalto token

At the bottom, there is a link: 'For more information about supported MFA devices, see [AWS Multi-Factor Authentication](#)'. The bottom right corner contains two buttons: 'Cancel' and 'Continue'.

IAM – Temporary Security Credentials

Temporary credentials are *just like* Programmatic Access Keys, except they are **temporary**.

Temporary credentials are useful in scenarios that involve:

- identity federation,
- delegation,
- cross-account access,
- and IAM roles

They can last from **minutes** to an **hour**.

They **are not stored with the user** but are generated dynamically and provided to the user when requested.

They are the basis for **roles** and **identity federation**.


You are already using Temporary Security Credentials.
AWS automatically generates them for IAM Roles.

IAM – Identity Federation

What is Identity Federation?

The means of linking a person's electronic **identity** and attributes stored across multiple distinct identity management systems

Identity Federation allows users to exist on a different platform.
eg Users are on Facebook but gain access as if they are a user in AWS

IAM supports 🙌 two types of identity federation

1. Enterprise identity federation
 - SAML (Microsoft Active Directory)
 - Custom Federation broker
2. **Web identity federation**
 - Amazon
 - Facebook
 - Google
 - OpenID Connect (OIDC) 2.0



OpenID Connect (**OIDC**) is an authentication layer on top of **OAuth 2.0**, an authorization framework.

IAM – Security Token Service (STS)

A web service that enables you to request **temporary, limited-privilege credentials** for IAM users or federated users

AWS Security Token Service (STS) is a **global service**, and all requests are sent to a single endpoint at <https://sts.amazonaws.com>

An STS will return:

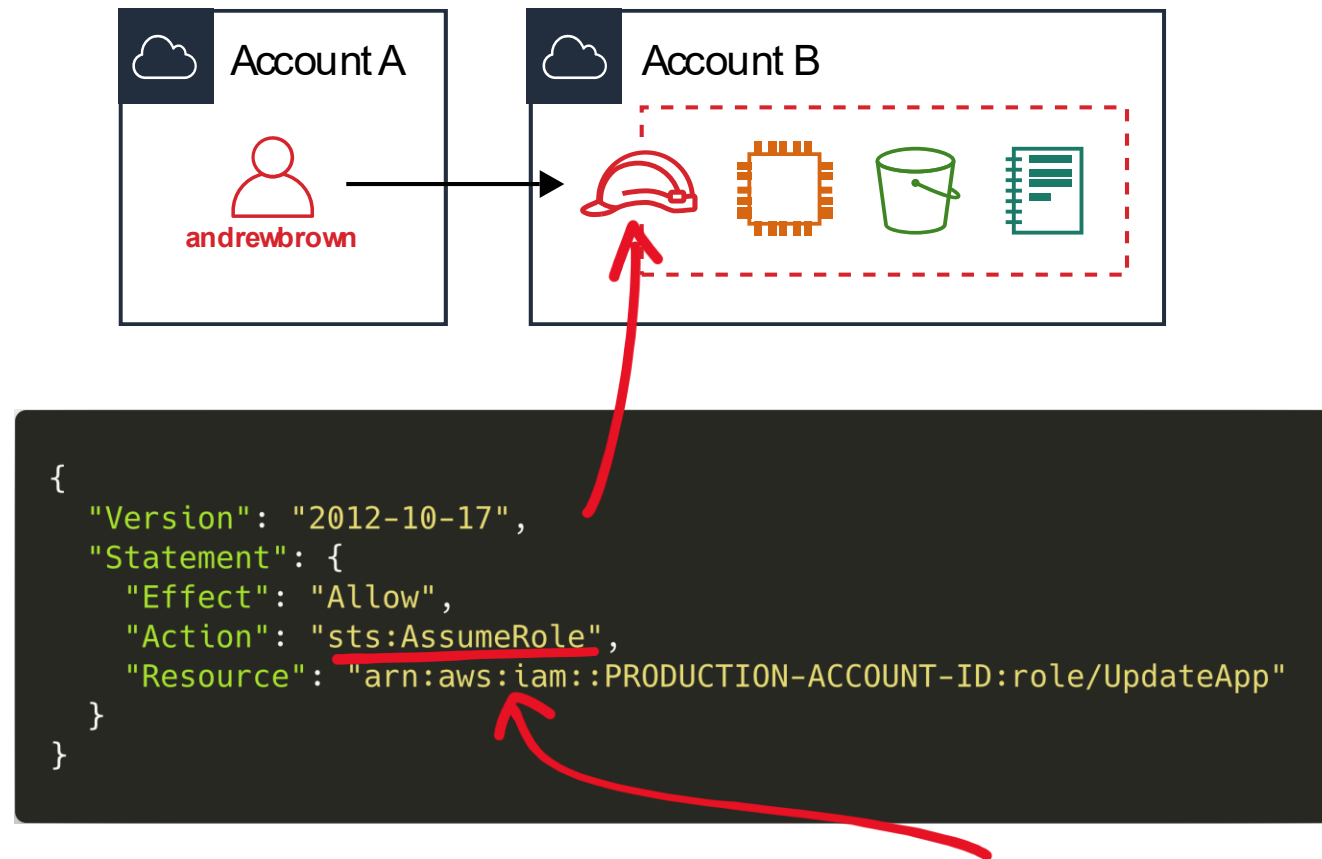
- **AccessKeyID**
- **SecretAccessKey**
- SessionToken
- Expiration

You can use the following API actions to obtain STS:

- **AssumeRole**
- AssumeRoleWithSAML
- **AssumeRoleWithWebIdentity**
- DecodeAuthorizationMessage
- GetAccessKeyInfo
- GetCallerIdentity
- GetFederationToken
- GetSessionToken

IAM –Cross Account Roles

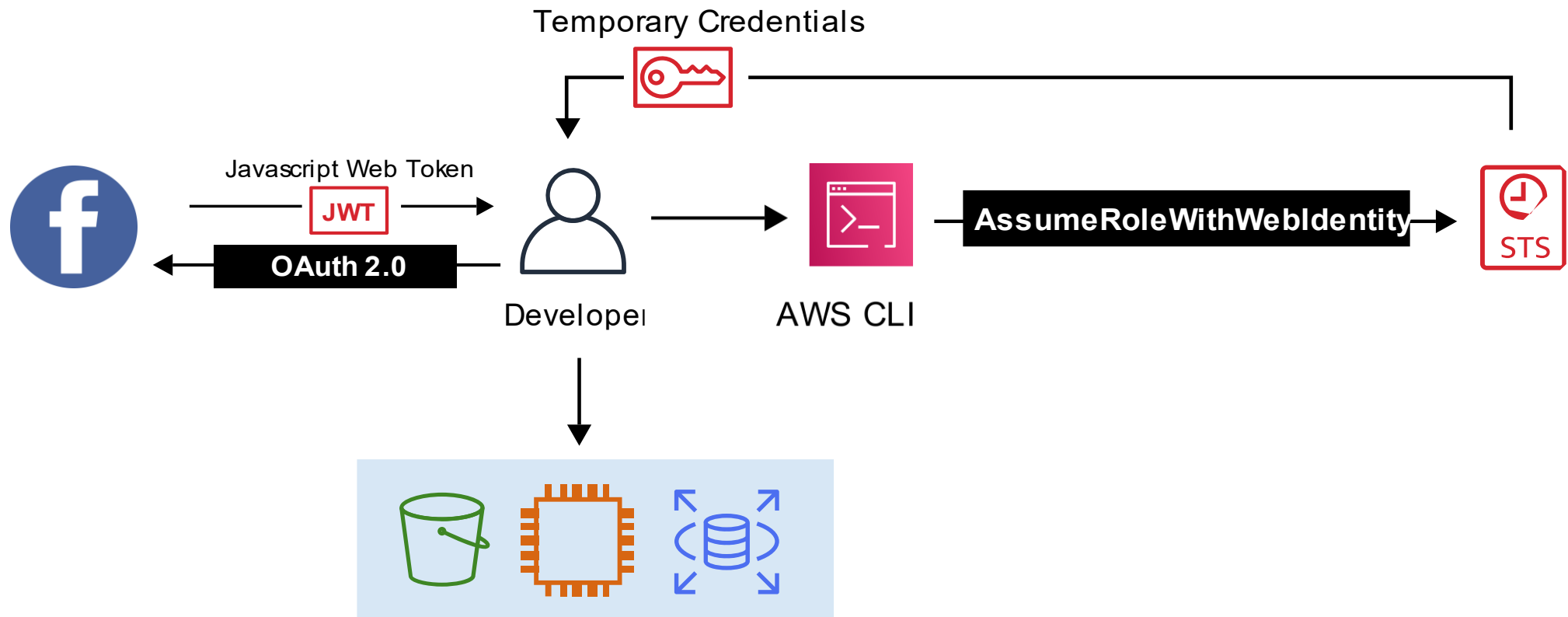
You can grant users from a different AWS account access to resources in your account through a **Cross-Account Role**. This allows you to avoid having to create them a user account within your system.



The role you create has a policy that grant access to the **sts:AssumeRole**

IAM - AssumeRoleWithWebIdentity

Returns a set of temporary security credentials for users who have been authenticated in a mobile or web application with a web identity provider.

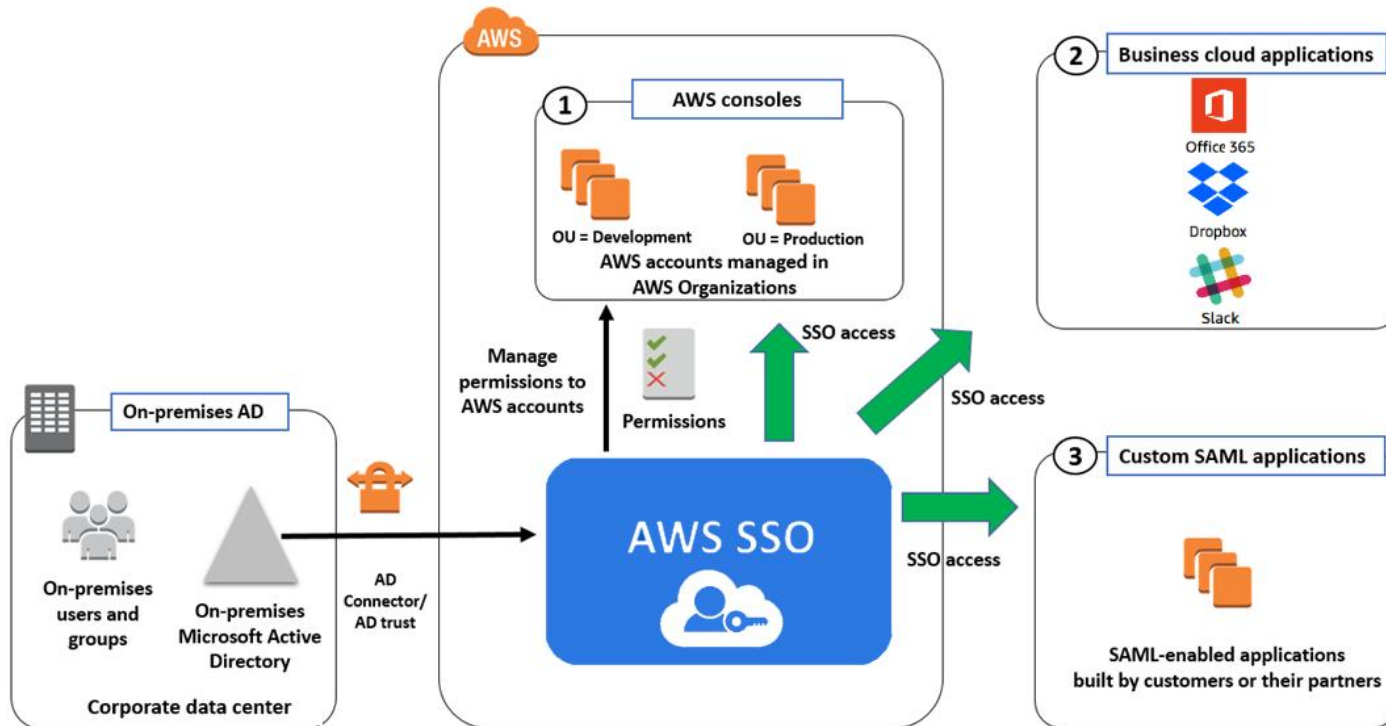


AWS Single-Sign On



AWS Single Sign-On (AWS SSO) is where you create, or connect, your workforce identities in AWS **once** and manage access centrally across your AWS organization.

AWS SSO Use Cases



Choose your Identity Source

- AWS SSO
- Active Directory
- SAML 2.0 IdP

Managed User Permissions Centrally

- AWS Account
- AWS Applications
- SAML Applications

Uses get Single Click Access